

DDTA - Scheda di lettura compilata

SRC-0003 - Sindre e Opdahl (2005) - Security requirements with misuse cases

Identita bibliografica

Campo	Valore
Titolo	Eliciting Security Requirements with Misuse Cases
Autori	Guttorm Sindre; Andreas Lothe Opdahl
Sede	Requirements Engineering, 10(1), 34-44
DOI	10.1007/s00766-004-0194-4
Pubblicazione online	24 giugno 2004
Tipo	Proposta e sintesi metodologica con applicazioni riportate
Compatibilita	Pre-codice; richiede o costruisce scenari funzionali strutturati

Validita temporale

Dimensione	Valutazione
Stato	Fondamento metodologico; non confronto SOTA attuale
Ancora valido	Scenari negativi, relazioni tipizzate, progressive refinement, traceability
Da aggiornare	Tool, automazione, evidenza industriale, confronto empirico
Uso tesi	Metodo documentation-primary; non prova completezza o automazione

Risultato centrale: l'analisi puo iniziare senza codice, ma non da informazione grezza. Servono almeno asset, obiettivi e scenari funzionali da minacciare o ostacolare.

Problema e contributo

I use case descrivono cio che deve accadere e tendono a trascurare cio che non deve accadere. Il paper introduce misuser, misuse case, security use case e le relazioni threaten e mitigate, insieme a template testuali e linee guida.

Metamodello essenziale

Entita / relazione	Significato
Use case	Comportamento funzionale desiderato
Misuser	Attore intenzionale o involontario che avvia il misuse
Misuse case	Sequenza che causa danno se completata
Security use case	Contromisura o requisito di sicurezza
Threaten	Il misuse ostacola o sfrutta il use case
Mitigate	Il security use case riduce la probabilita di successo del misuse

SRC-0003 - Processo e contratto di input

Cinque passi

Passo	Attività
1	Identificare asset critici
2	Definire obiettivi di sicurezza per ogni asset
3	Identificare misuser e sequenze di azioni dannose
4	Analizzare rischio e costi di protezione
5	Definire requisiti o contromisure coerenti con rischio e costo

Input minimo per DDTA

Input	Stato
Asset	Richiesto dal processo
Attori e stakeholder	Richiesti o creati dall'analista
Obiettivi funzionali	Richiesti
Scenari / use case	Richiesti o costruiti prima dell'overlay
Obiettivi di sicurezza	Richiesti o elicitati
Assunzioni e precondizioni	Necessarie per il dettaglio
Codice	Non richiesto

Descrizione lightweight

Un campo o una colonna Threats viene aggiunto al use case. Il campo vuoto segnala che la sicurezza non è stata ancora investigata; una disposizione esplicita registra che probabilità o impatto sono stati considerati non materiali.

Descrizione extensive

Campo	Funzione
Basic / alternative paths	Sequenze dannose e varianti
Mitigation points	Punti in cui il percorso può essere interrotto
Trigger	Evento o stato che avvia il misuse
Assumptions / preconditions	Condizioni ambientali e di sistema
Mitigation guarantee	Risultato di sicurezza richiesto
Business rules	Regole violate o vincolanti
Misuser profile	Intento, insider/outsider, competenza
Stakeholders and risks	Impatto per ciascun interessato

Classificazione: `documentation_primary_structured_scenarios_required_or_created`.

SRC-0003 - Evidenza, traceability e limiti

Traceability

Catena	Uso DDTA
Use case -> misuse case	Comportamento funzionale minacciato
Misuse case -> security use case	Threat candidate -> contromisura
Security use case -> threat	Razionale del requisito di sicurezza
Iteration / level	Progressive refinement
Assumptions / risks	Evidenza per review e change impact

Ruolo umano e automazione

L'identificazione di asset, obiettivi, misuser, percorsi, rischi e contromisure è manuale. Repository di pattern possono aiutare, ma il paper non propone estrazione automatica, un classificatore o un generatore di minacce.

Evidenza riportata

Evidenza	Interpretazione
EU knowledge-map project	Utilità e comprensibilità riportate
Framework CORAS in sei progetti	Applicazione realistica, non benchmark comune
Interviste su pattern	Comprensibilità della notazione
Trade-off analysis industriale	Esperienza positiva riportata
Conclusione degli autori	Serve validazione industriale più conclusiva

Limiti

Limite	Conseguenza
Linee guida aperte	Bassa ripetibilità
Molti asset e minacce	Analysis paralysis
Stopping non definito	Nessuna completezza globale
Attore o sequenza assente	Scarsa applicabilità
Use case non disponibile	Serve una trasformazione preliminare
Evidenza descrittiva	Nessuna superiorità dimostrata

Una review disposition per scenario è utile, ma non sostituisce coverage report e stopping condition globali.

SRC-0003 - Implicazioni DDTA e prossima lettura

Elementi direttamente supportati

- La prima analisi può precedere codice e design dettagliato.
- Scenari funzionali possono essere trasformati in scenari negativi.
- Threat e requisito di sicurezza devono restare entità distinte.
- Assunzioni, precondizioni e garanzie di mitigazione devono essere esplicite.
- L'analisi può passare da copertura leggera a dettaglio sui casi ad alto rischio.
- I link supportano spiegazione e change management.

Contratto candidato per un overlay misuse-case

Controllo	Requisito DDTA
View	Scenario view derivata dalla Base Analysis
Input	Asset, actor, goal, activity, interaction, scope
Output	Misuser, misuse scenario, threatened subject, mitigation candidate
Provenance	Ogni elemento collegato a Base Analysis e documento
Incertezza	Distinguere extracted, supplied e inferred
Review	Candidate -> proposed -> accepted/rejected
Coverage	Disposizione per scenario + stopping globale
Evolution	Rieseguire sui soggetti impattati dal cambiamento

Cosa non possiamo sostenere

- Che documentazione arbitraria produca automaticamente use case.
- Che tutte le minacce siano sequenze con un misuser identificabile.
- Che il metodo garantisca completezza.
- Che il metodo sia automatizzato o superiore alle alternative.
- Che misuse case e Base Analysis debbano coincidere.

Prossimo documento

SRC-0004 - van Lamsweerde: anti-models goal-oriented. Il confronto dovrà verificare se un modello formale di goal, anti-goal e obstacle offre regole e assurance più forti, quale documentazione presuppone e quanto resta dipendente dall'analista.